Week 2 Theoretical Knowledge

1. Alert Priority Levels

1.1 Core Concept

Alert priority levels define the **severity and urgency of security alerts** to help SOC analysts decide how fast to respond.

1.2 Priority Definitions

Critical

- Severe security incidents with immediate impact
- Active exploitation or major damage
- Examples:
  - Ransomware encrypting systems
  - Live data breach
  - System-wide compromise

High

- Serious incidents requiring urgent response
- Examples:
  - Unauthorized admin access
  - Malware execution confirmed
  - Privilege escalation attempts

Medium

- Suspicious activity requiring investigation
- Examples:
  - Repeated failed login attempts
  - Unusual network traffic
  - Possible brute-force attempts

Low

- Informational or low-risk events
- Examples:
  - Port scans
  - Minor anomalies
  - Non-malicious reconnaissance

1.3 Assignment Criteria

Alert priority is determined using:

- **Asset Criticality**
  - Production server > Test VM
- **Exploit Likelihood**
  - Known CVEs with public exploits = higher priority
- **Business Impact**

- Financial loss, downtime, data exposure

1.4 CVSS Scoring System

- CVSS = Common Vulnerability Scoring System
- Score range: **0.0 to 10.0**

Example:

- Log4Shell (CVE-2021-44228) = **9.8 (Critical)**

1.5 References

- CVSS Guidelines (FIRST)
- NIST SP 800-61
- SOC risk scoring concepts (Splunk model reference)

2. Incident Classification

2.1 Core Concept

Incident classification is the process of **categorizing security events into structured types** for faster analysis and response.

2.2 Incident Types

- Malware attacks
- Phishing attacks
- DDoS attacks
- Insider threats
- Data exfiltration

Example:

- Insider threat = employee stealing data

2.3 Classification Frameworks

MITRE ATT&CK

MITRE ATT&CK

- Maps attacker behavior using TTPs
- Example: T1566 = Phishing

ENISA Taxonomy

ENISA

- Standard classification of cyber incidents

VERIS Model

VERIS

- Structured format for incident reporting

2.4 Contextual Metadata

Each incident must include:

- Timestamp
- Source IP

- Target system
- Indicators of Compromise (hashes, URLs, domains)

2.5 Objective
To ensure **consistent classification and structured investigation of incidents**.

3. Basic Incident Response
3.1 Core Concept
Incident response is a structured process used to **detect, handle, and recover from cyberattacks**.

3.2 Incident Lifecycle
1. Preparation
- Build tools, policies, and response plans

2. Identification
- Detect and confirm the incident

3. Containment
- Stop the attack from spreading

4. Eradication
- Remove malware and attacker access

5. Recovery
- Restore systems to normal operation

6. Lessons Learned
- Analyze incident and improve security

3.3 Procedures
- System isolation
- Evidence preservation (logs, memory dumps, hashes)
- Communication between teams
- Use of automation tools (SOAR systems)

3.4 References
- NIST SP 800-61
- SANS Institute Incident Response Handbook
- LetsDefend training platform

3.5 Objective
To build the ability to **respond to cyber incidents in a structured and professional manner**.